Lecture Notes: Fundamentals of Information Security

1. Basic Security Concepts: The Bedrock of Protection

Information Security is not merely about setting passwords; it is the practice of protecting information by mitigating information risks. At its core, the discipline is guided by several foundational principles.

The CIA Triad

The **CIA Triad** is the most industry-standard model for designing security policies. It represents the three pillars of data protection:

- **Confidentiality:** This ensures that sensitive information is accessed only by authorized individuals. It prevents the disclosure of information to unauthorized parties. Encryption, access control lists (ACLs), and two-factor authentication are primary tools used to maintain confidentiality.
- **Integrity:** Integrity involves maintaining the consistency, accuracy, and trustworthiness of data over its entire life cycle. Data must not be changed in transit or at rest by unauthorized people. Digital signatures and checksums are common methods used to verify that data has not been tampered with.
- **Availability:** Information is useless if it cannot be accessed when needed. Availability ensures that systems, networks, and applications are up and running for authorized users. This is maintained through hardware redundancy (like RAID), regular backups, and protection against Distributed Denial of Service (DDoS) attacks.

Beyond CIA: Essential Extensions

While CIA covers the "what," other concepts cover the "who" and the "how":

- **Authentication:** The process of verifying the identity of a user, device, or system. It answers the question, "Are you who you say you are?" This is typically achieved through something you know (password), something you have (token), or something you are (biometrics).
- **Accountability:** This ensures that every action taken on a system can be traced back to a specific entity. Without accountability, it is impossible to determine who performed a malicious or accidental action. This is primarily achieved through robust logging and auditing.
- **Non-Repudiation:** This concept ensures that a party in a communication cannot deny having sent or received a message. For example, if you send an email with a digital signature, non-repudiation prevents you from later claiming you didn't send it. It provides legal and technical "proof" of an action.

---

2. Understanding the Hierarchy of Danger: Vulnerabilities to Exploits

In cybersecurity, we often use terms like "threat" and "risk" interchangeably in casual conversation, but in a technical context, they have very specific, distinct meanings. Understanding the relationship between these four terms is vital for security professionals.

Vulnerability

A **vulnerability** is a weakness or a "hole" in a system, process, or physical environment. It is a flaw that could potentially be used by an attacker to cause harm.

- *Examples:* A bug in software code, an unpatched operating system, a weak password, or an unlocked server room door.
- *Key Characteristic:* A vulnerability is passive; it exists whether someone knows about it or not.

Threat

A **threat** is any potential danger that could take advantage of a vulnerability to cause loss or damage. A threat requires an actor (a "threat actor") or a force of nature.

- *Examples:* A hacker looking for open ports, a disgruntled employee, a computer virus, or even a natural disaster like a flood.
- *Key Characteristic:* A threat is the "who" or "what" that might cause harm.

Risk

Risk is the probability or likelihood that a threat will successfully trigger a vulnerability, resulting in a loss. Risk is a calculation: $Risk = Threat \times Vulnerability$.

- *Context:* If you have a vulnerability (an unpatched laptop) but no threat (it's locked in a lead box at the bottom of the ocean), the risk is zero. Conversely, if there is a threat (hackers) but no vulnerability (perfectly secure systems), the risk is also zero. High risk occurs when a potent threat meets a glaring vulnerability.

Exploit

An **exploit** is the actual method, tool, or piece of code used to take advantage of a vulnerability. While the vulnerability is the "hole," the exploit is the "drill" used to widen it.

- *Examples:* A specific script that uses a buffer overflow to gain admin access, or a phishing email designed to trick a user into revealing a password.
- *Key Characteristic:* An exploit is the realization of a threat.

---

3. Practical Application: The Security Workflow

When a security professional looks at a system, they perform a **Risk Assessment**.

1. **Identify Assets:** What are we protecting? (e.g., Customer database).
2. **Identify Vulnerabilities:** Where are the weaknesses? (e.g., The database uses an old version of SQL).
3. **Identify Threats:** Who wants in? (e.g., Competitors or cybercriminals).
4. **Calculate Risk:** How likely is it they will find that SQL bug? What is the impact if they do?
5. **Mitigation:** Apply controls. We might patch the SQL (removing the **vulnerability**) or implement a firewall (blocking the **threat**'s path).

By balancing these concepts, organizations move from a reactive state—fixing things after they break—to a proactive state, where they understand their weaknesses and guard them accordingly.

Multiple Choice Questions (MCQs)

1. Which pillar of the CIA triad is compromised if a hacker crashes a web server?

A. Confidentiality

B. Integrity

C. Availability

D. Non-Repudiation

Answer: C. Availability.

Explanation: Crashing a server makes it inaccessible to authorized users, which is a direct violation of the Availability principle.

2. A digital signature is primarily used to ensure which of the following?

A. Confidentiality and Risk

B. Integrity and Non-Repudiation

C. Availability and Authentication

D. Exploitation and Vulnerability

Answer: B. Integrity and Non-Repudiation.

Explanation: A digital signature proves the data hasn't been changed (Integrity) and proves who sent it so they cannot deny it (Non-Repudiation).

3. Which term refers to the "likelihood" of a negative event occurring?

A. Threat

B. Vulnerability

C. Risk

D. Exploit

Answer: C. Risk.

Explanation: Risk is a measure of probability and impact—the chance that a threat will exploit a vulnerability.

4. If a software programmer leaves a "backdoor" in a program's code, what has been created?

A. A Threat

B. A Risk

C. A Vulnerability

D. An Exploit

Answer: C. A Vulnerability.

Explanation: The backdoor itself is a weakness in the system, which qualifies as a vulnerability.

5. Verification of a user's identity is known as:

A. Accountability

B. Authorization

C. Authentication

D. Integrity

Answer: C. Authentication.

Explanation: Authentication is the process of confirming that a user is who they claim to be.

6. Which of the following is an example of an "Exploit"?

A. A hurricane hitting a data center

B. A piece of code that takes advantage of a Windows bug

C. A weak password policy

D. An unencrypted hard drive

Answer: B. A piece of code that takes advantage of a Windows bug.

Explanation: An exploit is the specific tool or method used to trigger a vulnerability.

7. Logging all user activities so that actions can be traced to them is an example of:

A. Confidentiality

B. Accountability

C. Non-Repudiation

D. Authentication

Answer: B. Accountability.

Explanation: Accountability relies on logs and audits to associate specific actions with specific users.

8. Encrypting a hard drive primarily protects which pillar of the CIA Triad?

A. Confidentiality

B. Integrity

C. Availability

D. Accountability

Answer: A. Confidentiality.

Explanation: Encryption ensures that even if the drive is stolen, the data cannot be read by unauthorized parties.

9. What is the relationship between a threat and a vulnerability?

A. They are the same thing.

B. A vulnerability takes advantage of a threat.

C. A threat takes advantage of a vulnerability.

D. Both are used to calculate non-repudiation.

Answer: C. A threat takes advantage of a vulnerability.

Explanation: A threat (the danger) exploits a vulnerability (the weakness) to cause damage.

10. Hashing a file and comparing the hash later is a way to ensure:

A. Confidentiality

B. Integrity

C. Availability

D. Authentication

Answer: B. Integrity.

Explanation: If the hash changes, the file has been altered, meaning its integrity is lost.

11. A "Threat Actor" is best described as:

A. A weakness in a firewall

B. An entity that carries out a threat

C. The result of a successful hack

D. A backup power supply

Answer: B. An entity that carries out a threat.

Explanation: A threat actor is the person or group (like a hacker or insider) that initiates the threat.

12. Why is Non-Repudiation important in e-commerce?

A. It keeps credit card numbers secret.

B. It ensures the website is always online.

C. It prevents a customer from claiming they never placed an order.

D. It speeds up the checkout process.

Answer: C. It prevents a customer from claiming they never placed an order.

Explanation: Non-repudiation provides technical proof of a transaction that cannot be denied by either party.

13. RAID (Redundant Array of Independent Disks) is a technology used to improve:

A. Confidentiality

B. Authentication

C. Availability

D. Non-Repudiation

Answer: C. Availability.

Explanation: RAID allows a system to keep running even if a hard drive fails, ensuring the data remains available.

14. An "Insider Threat" refers to:

A. A hacker from a foreign country

B. Someone within the organization who poses a security risk

C. A virus found on the internet

D. A physical lock on a door

Answer: B. Someone within the organization who poses a security risk.

Explanation: Insider threats come from employees, contractors, or partners who have authorized access.

15. If the "Risk" of a specific attack is determined to be zero, it must mean:

A. There is no vulnerability OR no threat.

B. The system is perfectly encrypted.

C. All users have been authenticated.

D. The CIA triad is complete.

Answer: A. There is no vulnerability OR no threat.

Explanation: Since Risk = Threat x Vulnerability, if either value is zero, the total risk is zero.

Lecture Notes: Fundamentals of Computer Networking

Computer networking is the backbone of modern digital communication, allowing devices to exchange data and share resources. This set of notes covers the structural models, physical layouts, and logical addressing schemes that make the internet and local networks possible.

---

1. The OSI Reference Model

The **Open Systems Interconnection (OSI)** model is a conceptual framework developed by the International Organization for Standardization (ISO). It divides network communication into seven logical layers. This separation allows hardware and software developers to ensure their products can communicate across different platforms.

Layer 7: Application

This is the layer closest to the user. It provides network services directly to end-user applications. It identifies communication partners and determines resource availability.

- **Key Protocols:** HTTP (Web), FTP (File Transfer), SMTP (Email), DNS (Domain Name System).

Layer 6: Presentation

The Presentation layer acts as the "translator" for the network. It ensures that data sent from the application layer of one system can be read by the application layer of another. It handles data formatting, encryption, and compression.

- **Key Tasks:** Data encryption (SSL/TLS), JPEG, GIF, and MPEG formatting.

Layer 5: Session

This layer establishes, manages, and terminates connections (sessions) between applications. It acts as a moderator, ensuring that requests and responses are synchronized.

- **Key Protocols:** NetBIOS, RPC (Remote Procedure Call).

Layer 4: Transport

The Transport layer is responsible for end-to-end communication and error recovery. It ensures that data is delivered reliably and in the correct sequence.

- **Key Protocols:** * **TCP (Transmission Control Protocol):** Connection-oriented, reliable, ensures data arrives intact.
    - **UDP (User Datagram Protocol):** Connectionless, fast, used for streaming where occasional packet loss is acceptable.

Layer 3: Network

The Network layer handles the routing of data across different networks. It determines the best physical path for the data to take.

- **Key Protocols:** IP (Internet Protocol), ICMP (Internet Control Message Protocol).
- **Hardware:** Routers operate at this layer.

Layer 2: Data Link

This layer provides node-to-node data transfer. It packages data from the Network layer into "frames" and handles error detection from the Physical layer. It is subdivided into the Logical Link Control (LLC) and Media Access Control (MAC) sublayers.

- **Key Protocols:** Ethernet, PPP (Point-to-Point Protocol), Switch operations.
- **Hardware:** Switches and Bridges.

Layer 1: Physical

The lowest layer deals with the physical transmission of raw bitstreams over a physical medium (cables, fiber optics, or radio waves). It defines electrical, mechanical, and timing specifications.

- **Key Components:** Hubs, Repeaters, Cabling (Cat5e, Fiber).

---

2. Network Topology

Topology refers to the physical or logical arrangement of nodes (devices) and connections in a network. The choice of topology affects cost, scalability, and fault tolerance.

- **Bus Topology:** All nodes are connected to a single central cable (the backbone).
  - *Pros:* Easy to install, cheap.
  - *Cons:* If the backbone fails, the whole network goes down.
- **Star Topology:** Every node is connected to a central hub or switch. This is the most common topology in modern LANs.
  - *Pros:* If one cable fails, only that node is affected. Easy to troubleshoot.
  - *Cons:* If the central hub fails, the entire network is disabled.
- **Ring Topology:** Each node connects to exactly two other nodes, forming a continuous circle. Data travels in one direction (usually).
  - *Pros:* No central server needed.
  - *Cons:* If one node fails, the entire loop is broken.
- **Mesh Topology:** Every node is connected to every other node (Full Mesh) or some other nodes (Partial Mesh).
  - *Pros:* Extremely high fault tolerance.
  - *Cons:* Very expensive and complex to wire.
- **Tree Topology:** A hierarchical structure where star networks are connected via a bus backbone.

---

3. Addressing: MAC vs. IP

For data to reach its destination, devices must be uniquely identified. Networking uses two primary types of addresses:

MAC Address (Media Access Control)

- **Definition:** A permanent, physical address burned into the Network Interface Card (NIC) by the manufacturer.
- **Format:** 48-bit address, usually expressed as six groups of two hexadecimal digits (e.g., 00:1A:2B:3C:4D:5E).

- **Layer:** Operates at **Layer 2 (Data Link)**.
- **Purpose:** Used for communication within the same local network segment.

IP Address (Internet Protocol)

- **Definition:** A logical address assigned by software or a network administrator. It can change depending on the network the device is connected to.
- **IPv4:** 32-bit address represented in dotted-decimal format (e.g., 192.168.1.1).
- **IPv6:** 128-bit address represented in hexadecimal to accommodate the massive number of devices on the internet (e.g., 2001:0db8:85a3:0000:0000:8a2e:0370:7334).
- **Layer:** Operates at **Layer 3 (Network)**.
- **Purpose:** Used for routing data between different networks (Global communication).

---

4. Basic Protocols Summary Table

OSI Layer	Name	Primary Function	Example Protocols
Layer 7	Application	User Interface	HTTP, FTP, SMTP, DNS
Layer 4	Transport	Reliability / Flow Control	TCP, UDP
Layer 3	Network	Routing / Logical Addressing	IP, ICMP, IGMP
Layer 2	Data Link	Physical Addressing / Framing	Ethernet, ARP, PPP

Multiple Choice Questions (MCQs)

1. Which OSI layer is responsible for data encryption and compression?

A. Application

B. Presentation

C. Session

D. Transport

Answer: B. Presentation.

Explanation: The Presentation layer handles the syntax and semantics of the information transmitted, including encryption and compression.

2. At which layer do Routers operate?

A. Layer 1

B. Layer 2

C. Layer 3

D. Layer 4

Answer: C. Layer 3 (Network).

Explanation: Routers use IP addresses to route packets between different networks, which is a Layer 3 function.

3. What is the bit size of an IPv6 address?

A. 32-bit

B. 48-bit

C. 64-bit

D. 128-bit

Answer: D. 128-bit.

Explanation: IPv6 was designed with a 128-bit address space to replace the limited 32-bit space of IPv4.

4. Which topology requires a central controller or hub?

A. Mesh

B. Star

C. Bus

D. Ring

Answer: B. Star.

Explanation: In a star topology, all devices are connected to a central hub or switch which manages communication.

5. Which protocol is "connectionless" and does not guarantee delivery?

A. TCP

B. HTTP

C. UDP

D. FTP

Answer: C. UDP.

Explanation: User Datagram Protocol (UDP) is a connectionless transport protocol prioritized for speed over reliability.

6. A MAC address operates at which layer of the OSI model?

A. Physical

B. Data Link

C. Network

D. Transport

Answer: B. Data Link.

Explanation: MAC addresses are used for local delivery on a single segment, which is the responsibility of Layer 2.

7. Which protocol translates a domain name (like www.google.com) into an IP address?

A. ARP

B. DHCP

C. DNS

D. FTP

Answer: C. DNS.

Explanation: The Domain Name System (DNS) acts as the phonebook of the internet, mapping names to IP addresses.

8. What is the primary disadvantage of a Mesh topology?

A. Low security

B. High cost and complexity

C. Single point of failure

D. Slow data speeds

Answer: B. High cost and complexity.

Explanation: Because every node (or most nodes) must be interconnected, the amount of cabling and port requirements is very high.

9. Which OSI layer handles "Frames"?

A. Network

B. Transport

C. Data Link

D. Session

Answer: C. Data Link.

Explanation: Data units at Layer 2 are called Frames; at Layer 3 they are Packets, and at Layer 4 they are Segments.

10. What is the standard format for an IPv4 address?

A. Hexadecimal

B. Dotted-Decimal

C. Binary only

D. Alphanumeric

Answer: B. Dotted-Decimal.

Explanation: IPv4 addresses are typically written as four numbers (0-255) separated by periods.

11. Which protocol is used to automatically assign IP addresses to devices on a network?

A. DNS

B. SMTP

C. DHCP

D. ICMP

Answer: C. DHCP.

Explanation: Dynamic Host Configuration Protocol (DHCP) automatically provides IP addresses to new devices joining a network.

12. In a Bus topology, what happens if the central cable (backbone) breaks?

A. Only one node goes down.

B. The network continues via the other nodes.

C. The entire network fails.

D. The network switches to a ring topology automatically.

Answer: C. The entire network fails.

Explanation: The bus topology relies entirely on the single backbone; if it is severed, communication between all nodes ceases.

13. Which of these is a valid MAC address?

A. 192.168.1.50

B. 00-14-22-01-23-45

C. 2001:db8::1

D. http://www.network.com

Answer: B. 00-14-22-01-23-45.

Explanation: MAC addresses are 48-bit hexadecimal values, usually written in pairs separated by dashes or colons.

14. What does the "S" in HTTPS stand for?

A. Simple

B. Secure

C. System

D. Standard

Answer: B. Secure.

Explanation: HTTPS is HTTP over SSL/TLS, providing an encrypted and secure communication channel.

15. Which layer is responsible for dialogue control and synchronization?

A. Transport

B. Session

C. Presentation

D. Application

Answer: B. Session.

Explanation: The Session layer manages the start, stop, and restart of conversations between devices.

16. Which device acts as a "multi-port repeater" at the Physical layer?

A. Switch

B. Bridge

C. Hub

D. Router

Answer: C. Hub.

Explanation: A hub simply broadcasts incoming signals to all ports at Layer 1; it does not "read" addresses like a switch.

17. What is the main purpose of the ICMP protocol?

A. File transfer

B. Error reporting and diagnostics

C. Email delivery

D. Physical Addressing

Answer: B. Error reporting and diagnostics.

Explanation: ICMP (used by the 'ping' command) is used to send error messages and operational information.

18. "Full-Mesh" topology provides the highest level of:

A. Economy

B. Simplicity

C. Redundancy

D. Portability

Answer: C. Redundancy.

Explanation: With multiple paths between every node, the failure of any one link or node will not disrupt the rest of the network.

19. Which sublayer of the Data Link layer interacts with the Physical layer?

A. LLC (Logical Link Control)

B. MAC (Media Access Control)

C. Network Interface

D. Transport

Answer: B. MAC (Media Access Control).

Explanation: The MAC sublayer deals with the physical hardware address and the media access method.

20. Which protocol is used to send emails from a client to a server?

A. POP3

B. IMAP

C. SMTP

D. FTP

Answer: C. SMTP.

Explanation: Simple Mail Transfer Protocol (SMTP) is the standard for sending/pushing emails; POP3 and IMAP are used for receiving.

Lecture Notes: Fundamentals of Cryptography

Cryptography is the science of using mathematics to encrypt and decrypt data. It allows you to store sensitive information or transmit it across insecure networks (like the internet) so that it cannot be read by anyone except the intended recipient. Modern cryptography is a cornerstone of cybersecurity, ensuring privacy, trust, and security in the digital age.

---

1. Symmetric Key Cryptography

Symmetric cryptography, also known as secret-key or private-key cryptography, is the oldest and simplest form of encryption.

- **The Concept:** In this model, a **single, shared secret key** is used for both the encryption of plaintext and the decryption of ciphertext.
- **The Process:** 1. Sender and Receiver agree on a secret key.
  2. Sender encrypts the message using the key.
  3. Receiver decrypts the message using the same key.
- **Pros:** It is extremely fast and efficient, making it ideal for encrypting large amounts of data (like hard drives or database files).
- **Cons:** The primary challenge is **Key Distribution**. How do you get the secret key to the receiver securely? If an attacker intercepts the key during delivery, the entire system is compromised.
- **Common Algorithms:** AES (Advanced Encryption Standard), DES, Triple DES, and ChaCha20.

---

2. Asymmetric Key Cryptography (Public Key)

Asymmetric cryptography was developed to solve the key distribution problem of symmetric systems. It uses a **mathematically related pair of keys**.

- **The Key Pair:**
  - **Public Key:** Shared openly with everyone. It is used to **encrypt** data.
  - **Private Key:** Kept strictly secret by the owner. It is used to **decrypt** data.
- **The Process:** If Alice wants to send a secret message to Bob, she looks up Bob's public key. She encrypts the message with it. Now, *only* Bob's private key can unlock that message. Even Alice cannot decrypt it once it is encrypted.
- **Pros:** Solves the key exchange problem. You never have to share your private key.
- **Cons:** It is computationally expensive and much slower than symmetric encryption. It is usually used only to encrypt small amounts of data, like symmetric keys or digital signatures.
- **Common Algorithms:** RSA (Rivest-Shamir-Adleman), ECC (Elliptic Curve Cryptography), and Diffie-Hellman.

---

3. Cryptographic Hash Functions

A hash function is a mathematical algorithm that maps data of arbitrary size to a bit string of a fixed size (the "hash" or "digest").

- **Key Properties:**
    - **Deterministic:** The same input always produces the exact same hash.
    - **One-Way:** You cannot reverse the hash to find the original input.
    - **Collision Resistant:** It is extremely difficult to find two different inputs that produce the same hash.
    - **Avalanche Effect:** A tiny change in the input (like changing one bit) results in a completely different hash.
- **Use Cases:** Storing passwords (you store the hash, not the password), verifying file integrity, and blockchain technology.
- **Common Algorithms:** SHA-256, SHA-3, and MD5 (now considered insecure).

---

4. Message Authentication Code (MAC)

A MAC is a short piece of information used to authenticate a message—in other words, to confirm that the message came from the stated sender (authenticity) and has not been changed (integrity).

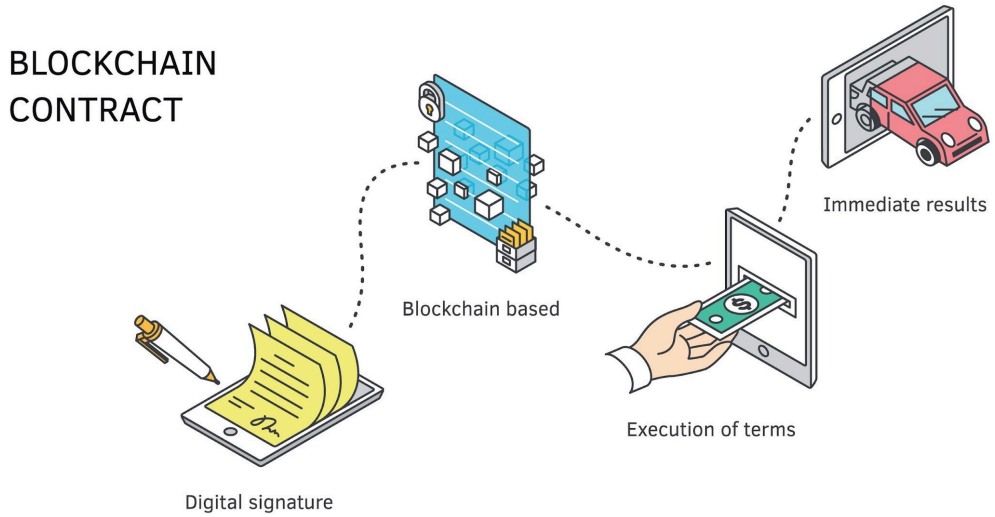
- **Mechanism:** Unlike a simple hash, a MAC uses a **secret key** in its calculation. It is often called a "keyed hash."
- **Process:** The sender inputs the message and a secret key into the MAC algorithm. The resulting code is sent with the message. The receiver performs the same calculation; if their code matches the one sent, the message is authentic.
- **Difference from Hash:** A hash ensures integrity; a MAC ensures **integrity AND authenticity**.
- **Common Type:** HMAC (Hash-based Message Authentication Code).

---

5. Digital Signatures

A digital signature is the digital equivalent of a handwritten signature or a stamped seal, but it is far more secure. It provides **Authentication, Integrity, and Non-Repudiation**.

- **The Process:**
    1. The sender creates a **hash** of the message.
    2. The sender encrypts that hash with their **Private Key**. This encrypted hash is the "Signature."
    3. The receiver decrypts the signature using the sender's **Public Key** to get the hash.
    4. The receiver hashes the message themselves and compares the two hashes.
- **Why it works:** Only the sender has the private key, so only they could have created the signature. If the message was altered, the hashes wouldn't match.



---

6. Digital Certificates and PKI

If someone sends you their public key, how do you know it actually belongs to them and not an imposter? This is the role of a **Digital Certificate**.

- **What is it?** An electronic "passport" that binds a public key to an identity (a person or organization).
- **Certificate Authority (CA):** A trusted third party (like DigiCert or Let's Encrypt) that issues these certificates. They verify the identity of the requester and "sign" the certificate.
- **Public Key Infrastructure (PKI):** The entire system of hardware, software, people, and policies used to create, manage, and revoke digital certificates.
- **Standard:** X.509 is the most common format for digital certificates.

Multiple Choice Questions (MCQs)

1. In symmetric encryption, how many keys are used for a communication between two parties?

A. One

B. Two

C. three

D. Four

Answer: A. One.

Explanation: Symmetric encryption uses a single shared secret key for both encryption and decryption.

2. Which algorithm is considered the current standard for symmetric encryption?

A. RSA

B. MD5

C. AES

D. Diffie-Hellman

Answer: C. AES.

Explanation: AES (Advanced Encryption Standard) is the worldwide standard for secure symmetric encryption.

3. If Alice wants Bob to send her an encrypted message using Asymmetric encryption, which key should she give him?

A. Alice's Private Key

B. Bob's Private Key

C. Alice's Public Key

D. Bob's Public Key

Answer: C. Alice's Public Key.

Explanation: To receive an encrypted message, you provide your Public Key so others can lock data for you.

4. What is the primary purpose of a Cryptographic Hash function?

A. Data Encryption

B. Key Exchange

C. Integrity Verification

D. Non-Repudiation

Answer: C. Integrity Verification.

Explanation: Hash functions create a unique fingerprint of data to ensure it hasn't been altered.

5. Which property ensures that a small change in input produces a massive change in the hash output?

A. Collision Resistance

B. Determinism

C. The Avalanche Effect

D. One-way Property

Answer: C. The Avalanche Effect.

Explanation: This makes it impossible to predict how changes to the input will affect the resulting hash.

6. What does a Message Authentication Code (MAC) require that a standard Hash does not?

A. A Public Key

B. A Secret Key

C. A Digital Certificate

D. A Salt

Answer: B. A Secret Key.

Explanation: A MAC is a keyed hash, requiring a secret key to prove authenticity.

7. A Digital Signature is created by encrypting a hash with which key?

A. The Sender's Public Key

B. The Sender's Private Key

C. The Receiver's Public Key

D. The Receiver's Private Key

Answer: B. The Sender's Private Key.

Explanation: Using the Private Key to sign ensures that only the owner could have produced the signature.

8. Which of the following provides Non-Repudiation?

A. Symmetric Encryption

B. Hashing

C. Digital Signatures

D. MACs

Answer: C. Digital Signatures.

Explanation: Because only the sender has their private key, they cannot deny having signed a document.

9. What is the role of a Certificate Authority (CA)?

A. To encrypt internet traffic

B. To store user passwords

C. To verify identities and issue digital certificates

D. To generate symmetric keys for users

Answer: C. To verify identities and issue digital certificates.

Explanation: A CA acts as a trusted third party in the PKI ecosystem.

10. Which asymmetric algorithm is based on the difficulty of factoring large prime numbers?

A. ECC

B. AES

C. RSA

D. SHA-256

Answer: C. RSA.

Explanation: RSA security relies on the mathematical complexity of prime factorization.

11. Which of these is a significant disadvantage of Asymmetric Encryption?

A. Key Distribution is difficult

B. It is computationally slow

C. It cannot provide non-repudiation

D. It only uses one key

Answer: B. It is computationally slow.

Explanation: Asymmetric math is far more complex than symmetric math, making it slower for large data.

12. "Salting" a hash is a technique primarily used for:

A. Digital Signatures

B. Encrypting hard drives

C. Protecting stored passwords

D. Speeding up AES

Answer: C. Protecting stored passwords.

Explanation: A salt is random data added to a password before hashing to prevent rainbow table attacks.

13. Which standard defines the format of Digital Certificates?

A. IEEE 802.11

B. X.509

C. FIPS 140-2

D. RFC 1918

Answer: B. X.509.

Explanation: X.509 is the international standard for the format of public key certificates.

14. If a hash function is "Collision Resistant," it means:

A. It is impossible to decrypt.

B. It is very hard to find two different inputs with the same output.

C. It only works on small files.

D. It requires a private key.

Answer: B. It is very hard to find two different inputs with the same output.

Explanation: A collision occurs when two different pieces of data produce the same hash.

15. Diffie-Hellman is primarily used for:

A. Data Encryption

B. Hashing passwords

C. Secure Key Exchange

D. Digital Signing

Answer: C. Secure Key Exchange.

Explanation: Diffie-Hellman allows two parties to create a shared secret key over an insecure channel.

16. What is the "Ciphertext"?

A. The original readable message

B. The encrypted, unreadable message

C. The key used for encryption

D. The digital signature

Answer: B. The encrypted, unreadable message.

Explanation: Plaintext is converted into ciphertext through the process of encryption.

17. In a PKI, what happens if a Private Key is stolen?

A. The user changes their Public Key manually.

B. The certificate is added to a Certificate Revocation List (CRL).

C. The CA deletes the internet.

D. The hash function is updated.

Answer: B. The certificate is added to a Certificate Revocation List (CRL).

Explanation: A CRL (or OCSP) informs others that a certificate is no longer trustworthy.

18. Which of the following is a "one-way" process?

A. Symmetric Encryption

B. Asymmetric Encryption

C. Hashing

D. Digital Certificates

Answer: C. Hashing.

Explanation: Hashing is designed to be a one-way function; you cannot "de-hash" data.

19. Why do we often use Asymmetric encryption to send a Symmetric key?

A. Because symmetric keys are too large for AES.

B. To combine the speed of symmetric with the security of asymmetric.

C. Because hashing doesn't work with symmetric keys.

D. To make the digital signature stronger.

Answer: B. To combine the speed of symmetric with the security of asymmetric.

Explanation: This is called a "hybrid cryptosystem," used in protocols like HTTPS.

20. Which hash algorithm is currently considered insecure due to collision vulnerabilities?

A. SHA-256

B. SHA-3

C. MD5

D. BLAKE2

Answer: C. MD5.

Explanation: MD5 is old and attackers can now easily generate collisions, making it unfit for security.

Lecture Notes: Application and Data Security

In a modern digital ecosystem, security must be applied at multiple levels. While network security protects the "pipes," Application and Data security protect the "intellectual property" and "services" that drive an organization. This lecture focuses on securing common applications and managing the lifecycle of data.

---

1. Application Security

Application security involves measures taken to improve the security of an application, often by finding, fixing, and preventing security vulnerabilities.

Database Security

Databases are the "crown jewels" of most organizations, storing sensitive customer, financial, and proprietary data.

- **Injection Prevention:** The most common threat is **SQL Injection (SQLi)**, where an attacker inserts malicious SQL code into entry fields for execution. This is mitigated through parameterized queries and input validation.
- **Access Control:** Implementing the **Principle of Least Privilege (PoLP)** ensures that users and applications only have the minimum level of access required to perform their functions.
- **Encryption at Rest:** Databases should be encrypted so that even if the physical storage media is stolen, the data remains unreadable.

E-mail Security

Email is the primary vector for malware delivery and social engineering.

- **Phishing Protection:** Organizations use spam filters and link-scanning tools to identify malicious emails.
- **Encryption:** Protocols like **S/MIME** or **PGP** provide end-to-end encryption, ensuring that only the intended recipient can read the message.
- **Authentication Protocols:** * **SPF (Sender Policy Framework):** Lists authorized IP addresses allowed to send mail for a domain.
    - **DKIM (DomainKeys Identified Mail):** Adds a cryptographic signature to emails to verify they weren't tampered with.
    - **DMARC:** A policy layer that tells receiving servers what to do if SPF or DKIM fails.

Internet/Web Security

Securing the interaction between users and web applications.

- **HTTPS/TLS:** Ensures all data transmitted between the browser and the web server is encrypted and authenticated.
- **Web Application Firewalls (WAF):** Unlike traditional firewalls, a WAF monitors and filters HTTP traffic to protect against attacks like Cross-Site Scripting (XSS).

---

2. Data Security Considerations

Data security is not a single act but a continuous lifecycle management process.

Backups

A backup is a copy of data used to restore the original after a data loss event.

- **The 3-2-1 Rule:** Keep **3** copies of data, on **2** different media types, with **1** copy kept **off-site**.
- **Frequency:** Determined by the **Recovery Point Objective (RPO)**—how much data the organization can afford to lose (e.g., 1 hour vs. 24 hours).

Archival Storage

Archiving is the process of moving data that is no longer actively used to a separate storage device for long-term retention.

- **Purpose:** Unlike backups (which are for recovery), archives are for **compliance** and historical reference.
- **Security:** Archives must be protected with the same level of encryption as live data, as they often contain sensitive historical records.

Disposal of Data

When data or hardware reaches the end of its life, it must be disposed of securely to prevent data remnants from being recovered.

- **Overwriting (Wiping):** Replacing data with patterns of 1s and 0s. Simple deletion only removes the "pointer" to the data, not the data itself.
- **Degaussing:** Using a strong magnetic field to disrupt the data on magnetic media (like HDDs or tapes). This does not work on SSDs.
- **Physical Destruction:** Shredding or incinerating the drive. This is the most secure method for end-of-life hardware.

Multiple Choice Questions (MCQs)

1. Which attack involves an attacker inserting malicious code into a database query?

A. Phishing

B. SQL Injection

C. Degaussing

D. XSS

Answer: B. SQL Injection.

Explanation: SQL Injection targets the database layer by manipulating input fields to execute unauthorized commands.

2. The "Principle of Least Privilege" is best described as:

A. Giving everyone admin access for efficiency.

B. Restricting users to only the data they need for their job.

C. Encrypting all emails.

D. Deleting data after 30 days.

Answer: B. Restricting users to only the data they need for their job.

Explanation: This limits the "blast radius" if an account is compromised.

3. Which email protocol uses a cryptographic signature to verify the sender's domain?

A. SPF

B. DKIM

C. SMTP

D. FTP

Answer: B. DKIM.

Explanation: DKIM (DomainKeys Identified Mail) provides a digital signature that proves the email originated from the claimed domain.

4. According to the 3-2-1 backup rule, how many copies should be kept off-site?

A. 3

B. 2

C. 1

D. 0

Answer: C. 1.

Explanation: Keeping at least one copy off-site protects data against local disasters like fire or flooding.

5. What is the primary difference between Backup and Archival?

A. Backups are encrypted; archives are not.

B. Backups are for recovery; archives are for long-term retention/compliance.

C. Archives are faster than backups.

D. Backups are only for databases.

Answer: B. Backups are for recovery; archives are for long-term retention/compliance.

Explanation: Backups are meant to restore systems quickly, while archives store data for years for legal or regulatory reasons.

6. Which disposal method is effective for magnetic hard drives but ineffective for Solid State Drives (SSDs)?

A. Overwriting

B. Physical Shredding

C. Degaussing

D. Incineration

Answer: C. Degaussing.

Explanation: Degaussing uses magnets; since SSDs store data electronically (flash), magnets do not erase the data.

7. A Web Application Firewall (WAF) primarily operates at which layer?

A. Physical Layer

B. Network Layer

C. Application Layer

D. Transport Layer

Answer: C. Application Layer.

Explanation: WAFs inspect HTTP traffic specifically to block application-level attacks like XSS or SQLi.

8. What does "Data at Rest" refer to?

A. Data being sent over email.

B. Data currently being processed by the CPU.

C. Data stored on a hard drive or database.

D. Data that has been deleted.

Answer: C. Data stored on a hard drive or database.

Explanation: "At rest" means the data is physically sitting on a storage medium.

9. Which of these is a "Physical Destruction" method for data disposal?

A. Reformatting the drive.

B. Shredding the disk into small pieces.

C. Moving files to the Recycle Bin.

D. Changing the file extension.

Answer: B. Shredding the disk into small pieces.

Explanation: Shredding ensures that the physical platters or chips cannot be reassembled to read data.

10. "RPO" in the context of backups stands for:

A. Recovery Point Objective

B. Remote Protocol Option

C. Redundant Process Order

D. Rapid Patch Operation

Answer: A. Recovery Point Objective.

Explanation: RPO defines the maximum age of files that must be recovered from backup storage for normal operations to resume.

Lecture Notes: Computer Networking & Security Technologies

Modern computing relies on the seamless interconnection of devices and the robust technologies that protect those connections. This lecture explores the fundamental concepts of networking and the primary defense mechanisms used to secure data in transit and at rest.

---

1. Basic Computer Network Concepts

A **Computer Network** is a collection of computers, servers, mainframes, network devices, or other devices connected to one another to allow the sharing of data.

- **LAN (Local Area Network):** Connects devices within a limited geographical area, such as a home, school, or office building. It offers high data transfer speeds.
- **WAN (Wide Area Network):** Covers a large geographical area, such as a country or even the entire world. The Internet is the most well-known example of a WAN.
- **Network Protocols:** These are sets of rules that govern how data is transmitted. Examples include **TCP/IP** (the foundation of the internet), **HTTP/HTTPS** (for web browsing), and **FTP** (for file transfers).
- **Packet Switching:** Most modern networks use packet switching, where messages are broken into small "packets." Each packet is sent independently across the network and reassembled at the destination.

---

2. Security Technology: Defensive Pillars

As networks grow, so does the attack surface. Security technologies are implemented to mitigate risks from external and internal threats.

Firewalls

A firewall is a network security device that monitors and filters incoming and outgoing network traffic based on an organization’s previously established security policies.

- **Function:** It acts as a barrier between a trusted internal network and an untrusted external network (like the Internet).
- **Types:** * **Packet Filtering:** Inspects packets in isolation.
    - **Stateful Inspection:** Monitors the state of active connections to determine which network packets to allow through.
    - **Next-Generation Firewalls (NGFW):** Adds deeper inspection, such as application awareness and integrated intrusion prevention.

Virtual Private Networks (VPNs)

A VPN creates a safe and encrypted connection over a less secure network, such as the public internet.

- **Tunneling:** It uses "tunneling" protocols to wrap data packets inside other packets, encrypting them in the process.

- **Use Case:** VPNs allow remote employees to access a company's internal LAN securely as if they were physically in the office.

Intrusion Detection Systems (IDS)

An IDS is a system that monitors network traffic for suspicious activity and issues alerts when such activity is discovered.

- **IDS vs. IPS:** While an **IDS** only *detects* and alerts, an **IPS (Intrusion Prevention System)** can actively *block* the suspicious traffic.
- **Detection Methods:**
    - **Signature-based:** Looks for specific patterns (like a virus "fingerprint").
    - **Anomaly-based:** Looks for deviations from "normal" network behavior.

Access Control

Access control is a security technique that regulates who or what can view or use resources in a computing environment.

- **Identification:** The user claims an identity (e.g., entering a username).
- **Authentication:** The user proves that identity (e.g., providing a password or biometric scan).
- **Authorization:** The system grants specific permissions (e.g., "User A can read this file, but cannot delete it").
- **DAC vs. MAC: Discretionary Access Control (DAC)** allows the owner of a resource to set permissions, while **Mandatory Access Control (MAC)** restricts access based on sensitive labels managed by a central authority.

Multiple Choice Questions (MCQs)

1. Which network type typically covers a single building or office?

A. WAN

B. LAN

C. PAN

D. MAN

Answer: B. LAN.

Explanation: Local Area Networks (LANs) are designed for short-range communication within a localized area like an office or home.

2. A firewall that tracks the context of a conversation rather than just individual packets is called:

A. Packet Filter

B. Stateless Firewall

C. Stateful Inspection Firewall

D. Proxy Server

Answer: C. Stateful Inspection Firewall.

Explanation: Stateful inspection looks at the state of active connections to ensure incoming packets are part of an established, legitimate session.

3. What is the primary purpose of a VPN?

A. To speed up the internet connection.

B. To provide an encrypted "tunnel" over a public network.

C. To detect viruses on a hard drive.

D. To assign IP addresses to local devices.

Answer: B. To provide an encrypted "tunnel" over a public network.

Explanation: VPNs use encryption and tunneling to ensure that data remains private and secure while traveling over the public internet.

4. What is the main difference between an IDS and an IPS?

A. IDS is hardware; IPS is software.

B. IDS alerts the admin; IPS alerts and takes action to block the threat.

C. IPS is used only for email; IDS is used for web traffic.

D. There is no difference.

Answer: B. IDS alerts the admin; IPS alerts and takes action to block the threat.

Explanation: An Intrusion Detection System is passive (monitoring), whereas an Intrusion Prevention System is active (protective).

5. Which component of Access Control determines what a user is allowed to do after they have logged in?

A. Identification

B. Authentication

C. Authorization

D. Auditing

Answer: C. Authorization.

Explanation: Authorization happens after authentication and defines the specific rights and permissions granted to the user.

6. An "Anomaly-based" IDS works by:

A. Searching for known malware signatures.

B. Monitoring for any behavior that deviates from an established "normal" baseline.

C. Blocking all traffic from foreign countries.

D. Encrypting the entire network database.

Answer: B. Monitoring for any behavior that deviates from an established "normal" baseline.

Explanation: Anomaly-based detection is useful for spotting new "Zero-Day" attacks that don't have a known signature yet.

7. In a network, "TCP/IP" refers to:

A. Hardware components like routers.

B. A suite of communication protocols.

C. A type of physical cabling.

D. A specific model of firewall.

Answer: B. A suite of communication protocols.

Explanation: TCP/IP is the standard set of rules that allows different computers to communicate over the internet.

8. Which access control model is managed by a central authority using security labels?

A. DAC (Discretionary Access Control)

B. RBAC (Role-Based Access Control)

C. MAC (Mandatory Access Control)

D. Physical Access Control

Answer: C. MAC (Mandatory Access Control).

Explanation: Under MAC, users cannot change permissions on their own files; instead, the system enforces a central policy based on sensitivity levels.

9. What happens to a message in a packet-switching network?

A. It is sent as one large, continuous file.

B. It is broken into smaller pieces and sent independently.

C. It is converted into a physical signal only.

D. it is deleted after being read once.

Answer: B. It is broken into smaller pieces and sent independently.

Explanation: Packet switching improves network efficiency by allowing different parts of a message to take the most efficient paths to the destination.

10. Biometric scanning (like a fingerprint) is an example of which phase of security?

A. Authorization

B. Authentication

C. Identification

D. Non-repudiation

Answer: B. Authentication.

Explanation: Biometrics are a form of "something you are," used to prove that a person is who they claim to be during the authentication process.

Lecture Notes: Modern Security Threats and Malicious Software

The landscape of cybersecurity is defined by a constant arms race between system administrators and threat actors. To protect an organization, one must understand the anatomy of the threats they face. This lecture covers the various forms of malicious software (malware), specialized attack techniques, and the evolving threat landscape of mobile devices.

---

1. Defining Malicious Software (Malware)

Malicious Software, or "Malware," is an umbrella term used to describe any software specifically designed to disrupt, damage, or gain unauthorized access to a computer system. Malware is characterized by its intent rather than its specific technical structure.

The Classics: Viruses, Worms, and Trojans

- **Viruses:** A computer virus is a type of malware that, when executed, replicates by inserting its own code into other computer programs, data files, or the boot sector of the hard drive.
    - *Key Characteristic:* It requires a **host program** and **human intervention** (like opening a file) to spread.
- **Worms:** Unlike viruses, worms are standalone software. They do not need to attach themselves to an existing program.
    - *Key Characteristic:* Worms are **self-replicating** and use network vulnerabilities to spread automatically from system to system without human help. They often consume massive amounts of bandwidth.
- **Trojan Horse:** Named after the Ancient Greek tale, a Trojan appears to be a useful or legitimate piece of software (like a free game or a utility) but contains hidden malicious functions.
    - *Key Characteristic:* It does not replicate. Instead, it relies on **deception** to trick users into installing it, often creating a "backdoor" for attackers.

---

2. Specialized Malware and Logic Triggers

Not all malware acts immediately upon infection. Many types are designed to wait for specific conditions.

- **Logic Bombs:** A string of malicious code inserted into an application that remains dormant until a specific logical condition is met.
    - *Example:* A disgruntled developer inserts code that deletes the company database if their employee ID is removed from the payroll system.
- **Time Bombs:** A subset of logic bombs where the trigger is a specific **date or time**.
    - *Example:* The "Michelangelo" virus, designed to activate every year on March 6th.
- **Event Bombs:** These trigger based on a specific user action or system event, such as the computer reaching a certain number of reboots or a specific file being opened.

- **Trapdoors (or Backdoors):** These are methods (often hidden entry points in code) that bypass normal authentication. While developers sometimes create them for legitimate troubleshooting, attackers install them to maintain persistent access to a compromised system.

---

3. Attack Methods: Spoofing and Email Threats

Communication channels are often exploited to bypass technical defenses.

- **Spoofing:** The act of masquerading as a trusted entity to gain access to a system or data.
    - **IP Spoofing:** Altering the source IP address in a packet to hide the sender's identity or impersonate another computer.
    - **Email Spoofing:** Forging the "From" address in an email so it appears to come from a known contact or legitimate organization.
- **Email Viruses:** These are transmitted via email attachments or links. Modern email viruses often use social engineering to convince the user to click a link that downloads malware.
- **Macro Viruses:** These are written in a "macro language" (like VBA) used by software applications like Microsoft Word or Excel. When a user opens a document containing a malicious macro, the virus executes, often infecting other documents on the system.

---

4. Denial of Service (DoS) and DDoS Attacks

A **Denial of Service (DoS)** attack is an attempt to make a machine or network resource unavailable to its intended users. It is an attack on **Availability**.

- **Mechanism:** The attacker floods the target with a volume of traffic or requests that the system cannot handle, causing it to crash or slow down to the point of being unusable.
- **DDoS (Distributed Denial of Service):** This is a more powerful version where the attack originates from **multiple sources** simultaneously. These sources are often "zombie" computers that form a **Botnet**. Because the traffic comes from thousands of different IP addresses, it is extremely difficult to filter or stop.

---

5. Threats on Mobile Devices

As smartphones become central to our lives, they have become prime targets for attackers.

- **Insecure Apps:** Malicious apps disguised as legitimate tools (Malware-as-an-App).
- **Smishing (SMS Phishing):** Phishing attacks delivered via text message, often containing links to fraudulent login pages.
- **Jailbreaking/Rooting Risks:** While users do this for more control, it removes the built-in security "sandboxing" provided by the OS, making the device much more vulnerable to malware.

- **Unsecured Wi-Fi:** Mobile devices often auto-connect to public Wi-Fi, allowing attackers to perform "Man-in-the-Middle" (MitM) attacks to intercept data.

Multiple Choice Questions (MCQs)

1. Which type of malware is "standalone" and does not require a host program to spread?

A. Virus

B. Worm

C. Macro Virus

D. Trojan Horse

Answer: B. Worm.

Explanation: Worms are independent programs that self-replicate across networks without needing to attach to other files.

2. A "Trojan Horse" is primarily defined by its use of:

A. Self-replication

B. Network flooding

C. Deception and trickery

D. Macro languages

Answer: C. Deception and trickery.

Explanation: A Trojan disguises itself as legitimate software to trick the user into executing it.

3. What is the trigger for a "Time Bomb"?

A. A specific number of mouse clicks

B. A specific date or system time

C. The deletion of a user account

D. A network request from a specific IP

Answer: B. A specific date or system time.

Explanation: Time bombs are programmed to execute their payload when the system clock reaches a pre-set value.

4. Which type of virus is embedded in documents like Word or Excel files?

A. Boot Sector Virus

B. Email Virus

C. Macro Virus

D. Worm

Answer: C. Macro Virus.

Explanation: Macro viruses use the internal scripting languages of office productivity software to execute malicious code.

5. A DDoS attack is primarily an attack against which pillar of security?

A. Confidentiality

B. Integrity

C. Availability

D. Non-Repudiation

Answer: C. Availability.

Explanation: The goal of a DDoS attack is to make a service or website unavailable to legitimate users.

6. What is a "Botnet"?

A. A type of firewall

B. A network of compromised "zombie" computers controlled by an attacker

C. A secure backup system

D. A programming language for robots

Answer: B. A network of compromised "zombie" computers controlled by an attacker.

Explanation: Botnets are commonly used to launch massive DDoS attacks or send spam.

7. "IP Spoofing" involves:

A. Stealing a physical hard drive

B. Forging the source address of a network packet

C. Encrypting an IP address

D. Installing a back door

Answer: B. Forging the source address of a network packet.

Explanation: Spoofing makes a packet appear to come from a trusted source to bypass security filters.

8. A "Logic Bomb" that triggers when an employee's name is removed from a database is an example of:

A. A Time Bomb

B. An Event-based Logic Bomb

C. A Worm

D. A Spoof

Answer: B. An Event-based Logic Bomb.

Explanation: It triggers based on a specific logical condition/event within the system.

9. What makes a "Distributed" Denial of Service (DDoS) harder to stop than a regular DoS?

A. It uses stronger encryption.

B. It originates from thousands of different locations simultaneously.

C. it only happens on mobile devices.

D. It targets the BIOS of the computer.

Answer: B. It originates from thousands of different locations simultaneously.

Explanation: Because the traffic is distributed, you cannot simply block one IP address to stop the attack.

10. Which term refers to a hidden entry point in a program that bypasses security?

A. Firewall

B. Trapdoor (Backdoor)

C. Spoof

D. Logic Bomb

Answer: B. Trapdoor (Backdoor).

Explanation: Trapdoors are intentionally or maliciously created holes in security that allow access without authentication.

11. "Smishing" is a phishing attack conducted via:

A. Voice calls

B. SMS (Text Messages)

C. Physical mail

D. Social Media ads

Answer: B. SMS (Text Messages).

Explanation: Smishing is a combination of "SMS" and "Phishing."

12. Why is "Jailbreaking" a mobile phone considered a security risk?

A. It makes the battery drain faster.

B. It voids the warranty.

C. It removes security "sandboxes" that prevent apps from accessing system data.

D. It prevents the phone from connecting to Wi-Fi.

Answer: C. It removes security "sandboxes" that prevent apps from accessing system data.

Explanation: Breaking the OS's built-in restrictions allows malware to gain deep access to the device.

13. A virus that requires a user to click an attachment in Outlook is called:

A. A Network Worm

B. An Email Virus

C. A Logic Bomb

D. A Trapdoor

Answer: B. An Email Virus.

Explanation: Email viruses use the mail system as their primary delivery mechanism.

14. What is the primary difference between a Virus and a Worm?

A. Only viruses are malicious.

B. A virus needs a host file and human action; a worm is a standalone, self-spreading program.

C. Worms only attack mobile devices.

D. Viruses are much faster than worms.

Answer: B. A virus needs a host file and human action; a worm is a standalone, self-spreading program.

Explanation: This is the fundamental distinction in how these two types of malware propagate.

15. Which of the following is an example of "Malicious Software"?

A. Antivirus

B. Ransomware

C. Device Driver

D. Operating System

Answer: B. Ransomware.

Explanation: Ransomware is a type of malware that encrypts data and demands payment.

16. "Event Bombs" are a subcategory of:

A. Trojans

B. Logic Bombs

C. Spoofing

D. Phishing

Answer: B. Logic Bombs.

Explanation: Logic bombs are the broad category for code that triggers based on specific conditions.

17. What does an attacker gain by using a "Trapdoor"?

A. They crash the system immediately.

B. They gain persistent, unauthorized access to the system.

C. They encrypt the user's files.

D. They hide the computer's IP address.

Answer: B. They gain persistent, unauthorized access to the system.

Explanation: Backdoors/Trapdoors are about maintaining access for future use.

18. Which threat exploits the trust between a user and a forged website?

A. Denial of Service

B. Spoofing/Phishing

C. Logic Bomb

D. Macro Virus

Answer: B. Spoofing/Phishing.

Explanation: These attacks rely on making a fake entity look like a real, trusted one.

19. Why are Macro viruses especially dangerous in a corporate environment?

A. They destroy hardware.

B. They spread through shared business documents (Word/Excel).

C. They only work on servers.

D. They cannot be detected by antivirus.

Answer: B. They spread through shared business documents (Word/Excel).

Explanation: Since businesses share many documents, macro viruses can spread very quickly across departments.

20. A mobile device connecting to a "Rogue Access Point" is likely a victim of:

A. A Time Bomb

B. A Man-in-the-Middle (MitM) Spoofing attack

C. A Macro Virus

D. A logic bomb

Answer: B. A Man-in-the-Middle (MitM) Spoofing attack.

Explanation: By tricking the phone into connecting to a fake Wi-Fi point, the attacker can intercept all transmitted data.

Lecture Notes: Security in E-Commerce and Electronic Payment Systems

E-commerce has revolutionized how we conduct business, but moving financial transactions to the digital realm introduces a unique set of security challenges. Protecting the integrity of the transaction, the privacy of the consumer, and the assets of the merchant is paramount.

---

1. Electronic Payment Systems (EPS)

An **Electronic Payment System** is a financial exchange that takes place online between buyers and sellers. The content of this exchange is usually a digital financial instrument (such as encrypted credit card numbers or digital cash) backed by a bank or an intermediary.

e-Cash (Digital Cash)

E-cash is a system that allows a person to pay for goods or services by transmitting a number from one computer to another.

- **Anonymity:** Like physical cash, e-cash can be designed to be anonymous.
- **The Process:** A user withdraws "digital coins" from their bank (which are cryptographically signed strings of data). They spend these coins at a merchant, who then verifies the coin with the bank to prevent **double-spending**.

Credit and Debit Cards

These are the most common forms of e-commerce payment.

- **Security Risks:** The primary threats include **Skimming** (stealing card info), **Phishing** (tricking users into revealing details), and **Card-Not-Present (CNP) Fraud**.
- **Protection Mechanisms:** Modern systems use **Tokenization**, where the actual card number is replaced by a unique "token" for the transaction, so the merchant never actually stores the sensitive data.

---

2. Public Key Cryptography (Asymmetric)

In the world of E-commerce, we cannot meet every merchant in person to exchange secret keys. **Public Key Cryptography** solves this.

- **The Key Pair:** Every user has two keys:
  - **Public Key:** Shared with everyone. Anyone can use it to encrypt a message for you.
  - **Private Key:** Kept secret. Only this key can decrypt messages encrypted with your public key.
- **Confidentiality:** If a customer wants to send their credit card info to a store, they encrypt it with the store's *Public Key*. Only the store can read it.

---

3. Digital Signatures

A digital signature is a mathematical technique used to validate the authenticity and integrity of a digital message or document. It is the digital equivalent of a handwritten signature or stamped seal.

- **How it works:** 1. The sender creates a hash (digest) of the document.
  2. The sender encrypts that hash with their own **Private Key**.
  3. The receiver decrypts the hash using the sender's **Public Key**.
  4. If the hashes match, the receiver knows the document is authentic and has not been tampered with.
- **Non-Repudiation:** This ensures that a sender cannot later deny having sent the message, which is vital for legal contracts in e-commerce.

---

4. Security Threats to E-Commerce

Beyond technical bugs, e-commerce faces targeted attacks:

- **Man-in-the-Middle (MitM):** An attacker intercepts the communication between the buyer and the website to steal credentials.
- **SQL Injection:** Attacking the merchant's database to steal stored customer records.
- **Phishing/Spoofing:** Creating a fake version of a popular e-commerce site to harvest credit card data.

Multiple Choice Questions (MCQs)

1. In Public Key Cryptography, if I want to send a secret message to "User A," which key should I use to encrypt the data?

A. My Private Key

B. My Public Key

C. User A's Private Key

D. User A's Public Key

Answer: D. User A's Public Key.

Explanation: You use the recipient's public key to encrypt data so that only their corresponding private key can unlock it.

2. Which property of a Digital Signature prevents a merchant from claiming they never received an order?

A. Confidentiality

B. Non-Repudiation

C. Availability

D. Scalability

Answer: B. Non-Repudiation.

Explanation: Non-repudiation provides proof of the origin of data, meaning the sender cannot deny the validity of the signature.

3. What is the primary security risk associated specifically with e-Cash?

A. Physical theft

B. Double-spending

C. Lack of speed

D. High transaction fees

Answer: B. Double-spending.

Explanation: Since e-cash is just digital data, security must be in place to ensure the same "coin" isn't spent twice by the same user.

4. A digital signature is created by encrypting a message hash with the:

A. Sender's Private Key

B. Sender's Public Key

C. Receiver's Private Key

D. Receiver's Public Key

Answer: A. Sender's Private Key.

Explanation: Signing with a private key proves that the signature could only have come from the owner of that key.

5. Which of the following is an advantage of e-Cash over Credit Cards?

A. It is always linked to a credit line.

B. It can provide higher levels of user anonymity.

C. It is easier to reverse a transaction.

D. It is widely accepted in all physical stores.

Answer: B. It can provide higher levels of user anonymity.

Explanation: Digital cash can be designed to function like physical currency, where the identity of the spender is not necessarily revealed to the merchant.

6. What is "Tokenization" in credit card processing?

A. Converting paper money to digital coins.

B. Replacing sensitive card data with a non-sensitive equivalent (token).

C. Encrypting the entire database with a single password.

D. Sending a physical token to the user's home.

Answer: B. Replacing sensitive card data with a non-sensitive equivalent (token).

Explanation: Tokenization ensures that if a merchant's database is hacked, the attacker only finds useless tokens rather than actual credit card numbers.

7. Public Key Cryptography is also known as:

A. Symmetric Cryptography

B. Asymmetric Cryptography

C. Hashing

D. Digital Watermarking

Answer: B. Asymmetric Cryptography.

Explanation: It is called "asymmetric" because it uses two different (but mathematically related) keys.

8. Which attack involves an attacker positioning themselves between a customer and a web server?

A. Brute Force

B. Man-in-the-Middle (MitM)

C. Logic Bomb

D. Trojan Horse

Answer: B. Man-in-the-Middle (MitM).

Explanation: A MitM attack allows the attacker to eavesdrop on or alter the communication between two parties.

9. The primary goal of a Digital Certificate in e-commerce is to:

A. Speed up the website.

B. Bind a public key to a specific entity (proving identity).

C. Store the user's password.

D. Provide a discount to the customer.

Answer: B. Bind a public key to a specific entity (proving identity).

Explanation: Digital certificates act like an ID card, verified by a trusted authority, to prove that a public key belongs to the legitimate store.

10. "Phishing" is a threat to e-commerce that primarily relies on:

A. Technical exploits in the browser.

B. Social engineering and deception.

C. Cracking 256-bit encryption.

D. Flooding a server with traffic.

Answer: B. Social engineering and deception.

Explanation: Phishing tricks users into providing sensitive information by pretending to be a trustworthy entity in an electronic communication.